

CS50's Introduction to Cybersecurity

Lecture 2 — Securing Systems

Harvard University | David J. Malan | cs50.harvard.edu/cybersecurity

Contents

1. Securing Systems — Overview	8. Ports & Port Scanning
2. Wi-Fi & WPA Encryption	9. Firewalls & Deep Packet Inspection
3. HTTP — Unencrypted Protocol	10. Malware — Viruses & Worms
4. Threats on HTTP	11. Botnets & Denial-of-Service Attacks
5. HTTPS & TLS	12. Antivirus Software
6. Certificate Authorities	13. Zero-Day Attacks
7. VPN & SSH	14. Summary — Key Concepts

1. Securing Systems — Overview

Lecture 2 shifts focus from how data is stored and encrypted (Week 1) to how systems and networks are secured during operation. Encryption remains central, but the threat landscape expands: data in motion across networks is exposed to a range of adversarial techniques that exploit both protocol weaknesses and human behavior.

This lecture covers the layered defenses — wireless encryption, secure protocols, virtual private networks, firewalls, and endpoint security — that collectively protect systems from network-level attacks, malware, and unauthorized access.

 **Key Insight:** System security is a layered problem. No single technology is sufficient; each layer addresses a different attack surface, and weaknesses in any one layer can compromise the whole.

2. Wi-Fi & WPA Encryption

Wireless networks broadcast data through radio signals that any device within range can potentially receive. This makes wireless communication inherently more exposed than wired connections, where physical access to the cable is required to intercept traffic.

Wireless networks fall into two categories:

- Unsecured (open) networks transmit data in plaintext. Any device on the same network can use a packet sniffer to capture and read all traffic passing over the network.

- Secured networks employ encryption to protect traffic between the user's device and the access point (router), making captured packets unreadable to eavesdroppers.

Wi-Fi Protected Access (WPA)

WPA is the encryption standard used to secure Wi-Fi networks. It encrypts wireless traffic between a device and the router. Current recommended versions are WPA2 and WPA3, which use strong cryptographic protocols. Older standards such as WEP (Wired Equivalent Privacy) have known cryptographic weaknesses and should not be used.

 **Key Insight:** *Even on a WPA-secured network, the encryption only protects traffic between the device and the router. Traffic beyond the router — traversing the open internet — requires additional protection such as HTTPS or a VPN.*

3. HTTP — Unencrypted Protocol

Hypertext Transfer Protocol (HTTP) is the foundational protocol for transmitting web content between a browser and a server. HTTP was designed without encryption — all data is sent in plaintext, meaning any intermediary with access to the network path can read or modify it.

HTTP operates on port 80. While functional for non-sensitive content, it is inappropriate for any communication involving credentials, personal data, or financial information.

 **Key Insight:** *HTTP's lack of encryption is not a bug — it was designed in an era when the internet was a trusted research network. The subsequent growth of the web and the rise of adversarial actors made unencrypted HTTP a systemic vulnerability.*

4. Threats on HTTP

Man-in-the-Middle (MITM) Attacks

In a MITM attack, an adversary positions themselves between the client and the server. Because HTTP traffic is unencrypted, the attacker can read, modify, or inject content into the data stream without either party's knowledge. Specific consequences include:

- Injection of advertisements or tracking scripts into web pages being loaded.
- Insertion of malicious code (e.g., JavaScript) that executes in the user's browser.
- Interception and theft of submitted form data such as login credentials.

Packet Sniffing

Packet sniffing involves capturing network packets as they traverse a shared medium (such as a Wi-Fi network). On an unsecured network, a packet sniffer can reconstruct entire HTTP sessions, revealing every URL visited, every form submitted, and every response received — including credit card numbers, passwords, and personal messages.

Cookies & Session Hijacking

Cookies are small data files that websites store in a user's browser to maintain state — tracking login sessions, shopping carts, preferences, and identities. When transmitted over HTTP, cookies are visible in plaintext.

Session hijacking occurs when an adversary captures a valid session cookie and uses it to impersonate the authenticated user — without ever needing the user's password. Additionally, a supercookie is a more persistent tracking mechanism that adversaries (or third parties) may inject to follow users across sites and sessions.

 **Key Insight:** *Session hijacking is particularly dangerous because it bypasses authentication entirely. Once an attacker has a valid session token, the server treats them as the legitimate user. This is why HTTPS — which encrypts cookies in transit — is essential for any authenticated session.*

5. HTTPS & TLS

HTTPS (HTTP Secure) is HTTP layered over TLS (Transport Layer Security), which provides encryption, authentication, and integrity verification for web traffic. HTTPS operates on port 443.

How TLS Works

TLS uses public-key cryptography to establish a secure session:

- The web server holds a public key and a private key.
- The server's public key is embedded in a digital certificate (type X.509), which is signed by a trusted Certificate Authority (CA).
- When a browser connects to an HTTPS site, it downloads the server's certificate and verifies its authenticity by hashing the certificate contents and comparing the result against the CA's signed hash using the CA's public key.
- If the hashes match, the browser is assured the certificate is legitimate and the connection proceeds securely using a session key derived via asymmetric cryptography.

SSL Stripping

SSL Stripping is an attack that downgrades a secure HTTPS connection to an unencrypted HTTP connection. An adversary positioned as a man-in-the-middle intercepts the initial HTTP request (before the browser upgrades to HTTPS) and relays communication to the server over HTTPS — while the victim communicates with the attacker over HTTP. The victim believes they have a secure connection; they do not.

An attacker may also redirect users to a fraudulent HTTPS-secured domain designed to appear legitimate, tricking them into entering credentials on a malicious site.

HTTP Strict Transport Security (HSTS)

HSTS is a server-side policy that instructs browsers to always connect to the domain over HTTPS, refusing any HTTP connection attempt. Once a browser has visited an HSTS-enabled site and recorded the policy, it will not allow a downgrade — even if a MITM attacker intercepts the connection and attempts to strip TLS.

 **Key Insight:** *HTTPS provides mathematical security guarantees, but the attack surface around it — SSL stripping, fraudulent certificates, and social engineering — demonstrates that cryptographic*

correctness alone does not ensure end-user security. Behavioral and policy controls like HSTS are necessary complements.

6. Certificate Authorities (CAs)

Certificate Authorities are trusted third-party organizations that digitally sign X.509 certificates, binding a domain name to a specific public key. This binding allows browsers to trust that the public key they receive from a server genuinely belongs to the claimed domain.

The trust chain works as follows:

- The CA verifies the domain owner's identity before issuing a certificate.
- The CA signs the certificate with its own private key.
- Browsers ship with a pre-installed list of trusted root CAs. Any certificate signed by a trusted CA is accepted.

This system places significant trust in CAs. A compromised or malicious CA could issue fraudulent certificates for any domain, enabling undetectable MITM attacks against HTTPS connections.

 **Key Insight:** *The CA trust model is a systemic dependency: security of the entire HTTPS ecosystem rests on the trustworthiness of a relatively small number of organizations. Certificate Transparency logs have been introduced as a public auditing mechanism to detect fraudulently issued certificates.*

7. VPN & SSH

Virtual Private Network (VPN)

A VPN creates an encrypted tunnel between the user's device and a VPN server. All network traffic is routed through this tunnel, providing two primary benefits:

- **Traffic is encrypted end-to-end between the device and the VPN server, protecting it from eavesdropping on the local network (e.g., on public Wi-Fi):** Confidentiality
- **Because traffic exits the VPN server rather than the user's device, external services see the VPN server's IP address — not the user's. This can be used to circumvent geographic content restrictions or obscure the user's physical location:** IP Masking

Important limitations:

- **A VPN shifts trust from the local network and ISP to the VPN provider, who can see all unencrypted traffic exiting the tunnel. A dishonest VPN provider represents a significant privacy risk:** Trust Shift
- **A VPN does not make a user anonymous. The VPN provider holds connection logs, and traffic beyond the VPN server (to destination sites) still uses the server's IP address, which can be traced back to the provider:** Not Full Anonymity

SSH (Secure Shell)

SSH is an encrypted network protocol that allows a user to securely log into and execute commands on a remote computer over an untrusted network. It replaces older, unencrypted protocols such as Telnet.

Example SSH command to connect to a remote server:

```
ssh stanford.edu
```

SSH uses public-key cryptography for authentication and symmetric encryption for the session. Access requires appropriate credentials — either a password or a private key paired with an authorized public key registered on the server. SSH operates on port 22.

 **Key Insight:** *SSH is one of the most security-critical tools in system administration. Misconfigured SSH access — such as password-based login on a public-facing server — is a common attack vector exploited by automated scanners and botnets.*

8. Ports & Port Scanning

A port is a logical endpoint on a networked device, identified by a number (0–65535), used to direct incoming and outgoing network traffic to specific services or applications. Ports allow a single device to run multiple network services simultaneously.

Common port assignments:

Port	Protocol	Purpose
80	HTTP	Unencrypted web traffic
443	HTTPS	Encrypted web traffic (TLS)
22	SSH	Encrypted remote command execution

Port Scanning

Port scanning is a reconnaissance technique in which an adversary systematically probes a range of port numbers on a target server to identify which ports are open and listening for connections. Open ports reveal which services are running — and thus which vulnerabilities may be exploitable.

Penetration Testing & Ethical Hacking

Penetration testing (pen testing) is the authorized, structured practice of simulating adversarial attacks on a system to identify security vulnerabilities before real attackers do. Port scanning is one of the first steps in a penetration test.

Ethical hacking is the legal profession built around this practice — security professionals are contracted to find and report vulnerabilities rather than exploit them maliciously.

 **Key Insight:** *The tools and techniques used by ethical hackers are identical to those used by malicious actors. The distinction lies entirely in authorization and intent. Understanding attack methods is a prerequisite for effective defense.*

9. Firewalls & Deep Packet Inspection

Firewalls

A firewall is a security system — implemented in software, hardware, or both — that monitors and controls incoming and outgoing network traffic based on predefined rules. Firewalls create a barrier between a trusted internal network and untrusted external networks.

Firewalls operate using IP addresses: each computer on a network is assigned a unique IP address, and firewall rules specify which IP addresses and port combinations are permitted or denied. This allows administrators to:

- Block traffic from known malicious IP addresses.
- Restrict which external services internal devices can reach.
- Prevent compromised internal services from communicating outward.

Deep Packet Inspection (DPI)

Standard firewalls examine packet headers (source/destination IP and port) but not the content (payload). Deep packet inspection examines the actual data within packets, enabling more granular policy enforcement:

- Detecting prohibited content, file types, or application protocols.
- Logging URLs accessed by users on the network.
- Blocking access to specific websites or categories of content.

Proxy Servers

DPI is implemented via a proxy — an intermediary device through which all network traffic is routed. The proxy decrypts, inspects, and re-encrypts traffic (in the case of HTTPS inspection), or simply logs and filters HTTP requests. Schools, corporations, and governments use proxies to enforce acceptable-use policies, block harmful content, and monitor network activity.

 **Key Insight:** *Deep packet inspection by a proxy is a significant privacy trade-off. On a corporate or school network, users should assume that URLs visited, content transmitted over HTTP, and potentially HTTPS content (via SSL inspection proxies) may be logged and reviewed by the network operator.*

10. Malware — Viruses & Worms

Malware (malicious software) is any software intentionally designed to disrupt, damage, or gain unauthorized access to a computer system. Malware encompasses a broad category of threats, each with distinct propagation mechanisms and payloads.

Viruses

A computer virus is a piece of malicious code that attaches itself to a legitimate program or file. When the infected program executes, the virus runs and can perform virtually any action: deleting files, stealing data, encrypting the hard drive, installing additional malware, or opening backdoor access for remote attackers. Critically, a virus typically requires user action (opening an infected file or program) to spread.

Worms

A worm is a self-replicating piece of malware that spreads autonomously across networks by exploiting security vulnerabilities — without requiring any user interaction. A worm propagates by scanning for vulnerable systems, exploiting a known or zero-day vulnerability to gain access, copying itself to the new host, and repeating the process. Worms can spread globally within hours, as demonstrated by historical incidents such as the Morris Worm (1988) and WannaCry (2017).

 **Key Insight:** *The key distinction between a virus and a worm is propagation. A virus needs a host file and user action; a worm is self-sufficient and can spread entirely on its own through network vulnerabilities. This makes worms capable of far more rapid and widespread damage.*

11. Botnets & Denial-of-Service Attacks

Botnets

A botnet is a network of computers infected with malware that allows an adversary (the botnet operator, or 'bot herder') to remotely control them as a coordinated group. Each infected computer is called a 'bot' or 'zombie.' The device owner typically has no knowledge that their computer has been compromised and enlisted in the botnet.

Botnets are built by distributing botnet malware through phishing emails, malicious downloads, drive-by downloads on compromised websites, or worm-based propagation. Once installed, the malware establishes a covert communication channel with the operator's command-and-control (C2) server.

Denial-of-Service (DoS) Attacks

A denial-of-service attack floods a target server with a volume of requests so large that legitimate users cannot be served — effectively taking the service offline. A single source can be blocked by IP address.

Distributed Denial-of-Service (DDoS) Attacks

A DDoS attack coordinates thousands to millions of botnet-compromised computers to simultaneously flood a target. Because requests originate from a vast number of different IP addresses worldwide, blocking by IP is impractical. DDoS attacks have taken down major websites, DNS providers, and internet infrastructure.

 **Key Insight:** *Botnets represent a direct externalization of harm: the owner of an infected computer bears the cost (degraded performance, bandwidth consumption, legal risk) while the attacker profits. This is why keeping devices patched and malware-free is not merely a personal interest but a collective one.*

12. Antivirus Software

Antivirus software is designed to detect, quarantine, and remove malicious software. It operates primarily through two mechanisms:

- **The antivirus maintains a database of known malware signatures (byte patterns unique to specific malware). Files and processes are scanned and compared against this database. Any match triggers an alert and remediation action.:** Signature-Based Detection
- **Modern antivirus tools also analyze behavior — flagging programs that exhibit suspicious patterns (e.g., attempting to modify system files, disable security software, or communicate with known malicious servers) even if no matching signature exists.:** Heuristic / Behavioral Detection

Automatic Updates

Antivirus effectiveness depends entirely on the currency of its signature database and the software itself. Automatic updates must be enabled so that:

- New malware signatures are downloaded as they are identified.
- Security vulnerabilities in the antivirus software itself are patched — attackers actively target security software as a high-value attack vector.

 **Key Insight:** *An antivirus with outdated signatures is only marginally better than no antivirus. Threat actors deliberately test their malware against major antivirus products before deployment, timing releases to exploit the window between malware release and signature issuance.*

13. Zero-Day Attacks

A zero-day vulnerability is a security flaw in software that is unknown to the software vendor and for which no patch exists. The term 'zero-day' refers to the fact that the vendor has had zero days to fix the problem — the vulnerability is being exploited before a defense can be developed.

A zero-day attack exploits such a vulnerability. Because no signature or patch exists, traditional antivirus and patch-based defenses are entirely ineffective. Zero-day exploits are highly valuable: they are bought and sold on both legitimate markets (governments and security firms) and criminal marketplaces.

The lifecycle of a zero-day:

- **A researcher or adversary identifies an unknown vulnerability.:** Discovery
- **The adversary develops and deploys an exploit before the vendor is aware.:** Exploitation
- **The vulnerability is reported (ideally through responsible disclosure) to the vendor.:** Disclosure
- **The vendor develops and releases a fix.:** Patch Development
- **Users apply the patch, closing the vulnerability.:** Patch Deployment

The danger window spans from Discovery through Patch Deployment — a period that can last days to months depending on the complexity of the fix and users' patching habits.

 **Key Insight:** *Zero-day vulnerabilities highlight the inherent asymmetry in cybersecurity: an attacker needs to find only one unknown flaw, while defenders must protect against all possible*

unknown flaws simultaneously. This is why defense-in-depth — multiple overlapping security layers — is essential.

14. Summary — Key Concepts

Concept	What It Does / Purpose	Key Limitation / Threat
Wi-Fi / WPA	Encrypts wireless traffic between device and router	Unsecured (open) networks expose all traffic to sniffing
HTTP	Transfers data between browser and server without encryption	Man-in-the-Middle, packet sniffing, session hijacking, cookie theft
HTTPS / TLS	Encrypts HTTP traffic using public-key cryptography + X.509	SSL Stripping can downgrade to HTTP; mitigated by HSTS
Certificate / CA	Third-party-signed proof of a server's public key identity	Compromised CA can issue fraudulent certificates
VPN	Encrypted tunnel masking source IP and protecting traffic	Shifts trust to VPN provider; does not guarantee full anonymity
SSH	Encrypted remote command execution on a server	Requires valid credentials and proper key management
Ports	Numbered endpoints directing traffic to specific services	Port scanning reveals open services; mitigated by firewalls
Firewall	Software blocking unauthorized inbound/outbound traffic	Does not inspect encrypted payloads without deep packet inspection
Deep Packet Insp.	Proxy examines packet contents for policy enforcement	Privacy trade-off; often used on corporate/school networks
Malware / Virus	Software that attaches and executes malicious actions	Can do nearly anything once installed; spreads via user action
Worm	Self-propagating malware exploiting security holes	No user interaction required to spread
Botnet / DDoS	Network of infected machines used to overwhelm a target	Distributed nature makes source blocking ineffective
Antivirus	Detects and removes known malware signatures	Ineffective against zero-day attacks until patches/signatures issued